

2023 23andMe Data Breach Forensic Investigation Report

Case number

DRIR-2023-23ME-001

Date of report

26 February 2026

Court information

In re: 23andMe, Inc. Customer Data Security Breach Litigation

Case No. 24-md-03098-EMC

United States District Court, Northern District of California

Currently pending under :

In re: Chrome Holding Co., et al.

Case No. 25-40976-357

United States Bankruptcy Court, Eastern District of Missouri

Disclaimer:

This report is a simulated digital forensic investigation created for educational and portfolio purposes. All analysis, logs, and findings discussed within are based entirely on publicly available threat intelligence, regulatory reports, and news articles regarding the 2023 23andMe data breach. No active penetration testing, unauthorized access, or internal system interaction was performed on any corporate infrastructure.

Table of Contents

1.0 Abstract.....	4
2.0 Case Background.....	5
2.1 Company Overview	6
2.2 Nature of Data Breach	7
2.3 Timeline of the Data Breach	8
2.4 Impact of the Data Breach	9
3.0 Scope and Objectives	11
3.1 Scope	11
3.1.1 In Scope.....	11
3.1.2 Out of Scope	11
3.2 Objectives.....	12
4.0 Legal Discussions	13
4.1 Legal Basis for the Forensic Investigation.....	13
4.1.1 International Regulatory Authority	13
4.1.2 Ongoing Court Cases.....	14
4.1.3 Forensic Standards for Expert Testimony.....	14
4.2 Compliance with Global Data Protection Standards.....	14
4.2.1 The Security Principle and Duty of Care.....	15
4.2.2 Breach Notification and Tracking.....	16
4.2.3 Special Category Data	16
4.3 Admissibility of Digital Evidence in Malaysia.....	16
4.3.1 Proving the Evidence is Real (Section 90A)	16
4.3.2 Using Expert Opinions (Section 45)	17
4.3.3 How Much Weight Does the Evidence Have? (Section 90B).....	17
4.4 Legal Mapping to Malaysian Cyber Laws.....	17
4.4.1 Unauthorized access to computer material (Section 3)	17
4.4.2 Unauthorized access with intent to commit or facilitate commission of further offence (Section 4)	17
4.4.3 Unauthorized modification of the contents of any computer (Section 5)	18
4.4.4 Abetments and attempts punishable as offences (Section 7)	18
4.5 Evidence Integrity and Forensic Standards.....	18
4.5.1 Adherence to ISO 27037 Standards.....	19

4.5.2 Cryptographic Verification	19
4.5.3 Chain of Custody Records	20
4.5.4 Professionalism and Court Readiness.....	24
5.0 Forensics Methodology	24
5.1 Forensic Tools and Techniques.....	24
5.2 Process of Acquiring, Preserving, and Analysing Digital Evidence	27
5.2.1 Acquiring Digital Evidence.....	28
5.2.2 Preserving Digital Evidence	28
5.2.3 Analysing Digital Evidence	28
6.0 Evidence Collection.....	30
6.1 Sources of Digital Evidence	31
6.1.1 Network Authentication and WAF Logs	31
6.1.2 DNA Relatives Profiles	32
6.1.3 Exfiltrated Specially Curated List.....	33
6.1.4 Raw Genotype Data Files	35
6.2 Procedures Followed During Evidence Collection.....	36
Step 1: Identification (ISO 27037 Stage 1)	36
Step 2: Collection (ISO 27037 Stage 2)	37
Step 3: Acquisition (ISO 27037 Stage 3).....	37
Step 4: Preservation (ISO 27037 Stage 4).....	37
6.3 Chain of Custody (CoC) Requirements.....	38
7.0 Data Preservation Techniques and Challenges.....	39
7.1 Data Preservation Techniques.....	39
7.2 Preservation and Investigation Challenges	39
8.0 Analysis and Findings	41
8.1 Authentication and Network Log	41
8.2 DNA Relatives Feature Exploitation.....	42
8.3 Dark Web Intelligence.....	43
9.0 Relevance to the Case	44
9.1 Network Authentication and WAF Logs	44
9.2 DNA Relatives Feature Data Exposure.....	44
9.3 Dark Web Marketplace Evidence.....	45
9.4 Raw Genetic Data Access	45

9.5 Overall Significance of Digital Evidence.....	46
10.0 Expert Opinions.....	47
10.1 Attack Methods and Security Weaknesses	47
10.2 Regulatory Experts Interpretations.....	48
10.3 Evidences Interpretations	49
11.0 Conclusions	51
12.0 Recommendations	52
13.0 References.....	53

1.0 Abstract

This report presents a digital forensic investigation into the October 2023 data breach at 23andMe, a biotechnology and personal genomics company. We examine how attackers utilized a "low-and-slow" credential stuffing attack—leveraging previously compromised passwords from unrelated breaches—to gain unauthorized access to user accounts between April and September 2023. By mimicking legitimate user behavior, the attackers successfully bypassed intrusion detection systems. While only about 18,000 accounts were directly breached, the incident's scale expanded drastically due to the exploitation of 23andMe's "DNA Relatives" feature. This interconnected data-sharing allowed attackers to scrape private profile details, ancestry reports, and raw genetic data, ultimately exposing the information of roughly 6.9 million users worldwide before the data was distributed on cybercrime forums. Furthermore, this investigation reconstructs the attack timeline, analyzes the technical mechanics of the breach, and categorizes the exposed digital evidence. To ensure the integrity and legal admissibility of our findings, we strictly adhered to established digital forensic standards, including ISO 27037 and SWGDE. Our methodology incorporates authentication and Web Application Firewall (WAF) log analysis, time-window event correlation, and dark web intelligence monitoring. All digital evidence was preserved using standard forensic imaging, verified with SHA-256 hashing, and secured with strict chain-of-custody documentation. Ultimately, our findings indicate that the breach was primarily caused by a critical combination of weak user authentication practices and the platform's highly interconnected data-sharing architecture.

2.0 Case Background



Figure 1.0 Genetic Testing Company - 23andMe

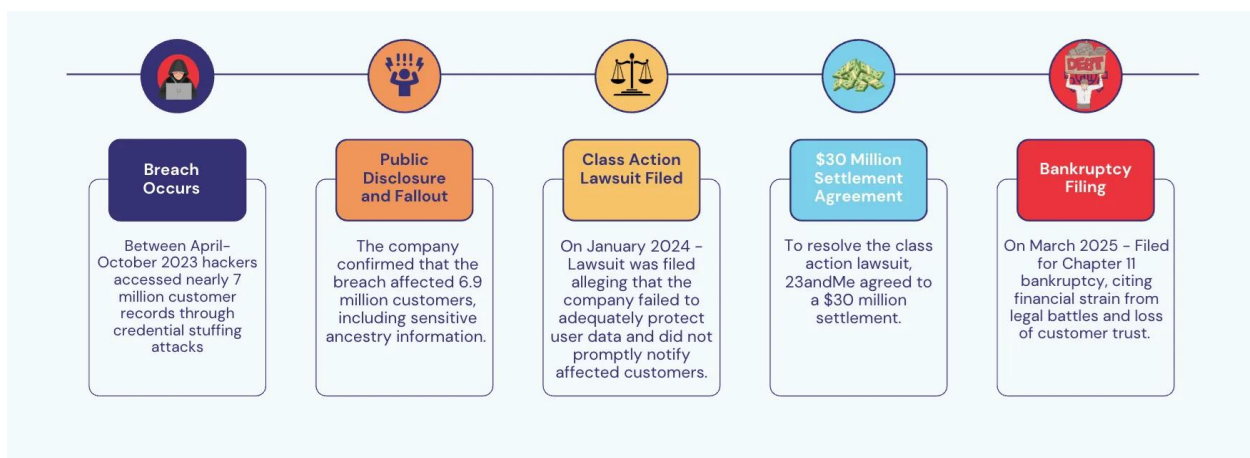


Figure 1.1 The Aftermath of the Data Breach (BluOcean Cyber, n.d.)

2.1 Company Overview

23andMe is an American biotechnology and personal genomics company (23andMe, n.d.). The company was established in 2006 and it is based in California. The core of its operation is to offer direct-to-consumer (DTC) genetic testing services, which enable people to know more about their ancestry, genetic characteristics, and health risks on the basis of the DNA (23andMe, 2023). In contrast to the old method of genetic testing used in traditional medicine that necessitated the involvement of a healthcare provider, 23andMe allows its customers to request DNA tests via the internet and view the test results via an online account or a smartphone application.

The process requires customers to buy a DNA testing kit and sample of saliva, which is dispatched to the laboratory of the company to analyze the genes. Once the DNA sample is processed, the outcomes are uploaded to the individual account of the user on the platform. With this account, users will be able to access various categories of reports such as ancestry composition, health predisposition reports, carrier status reports and wellness information. The company also has a service known as DNA Relatives that lets users find other users who share genetic markers with them and might be their distant relatives.

Since the company deals with millions of genetic and personal information of its users, it gathers and stores a vast quantity of sensitive data. These are personal identification information like names, email address, profile and genetic information based on the DNA samples of customers. The company can also use some of this genetic information as a source of scientific research and medical studies with the consent of the customer (Information Commissioner's Office and the Office of the Privacy Commissioner of Canada, 2024).

As genetic data is very sensitive, the companies such as 23andMe will have high data protection and cybersecurity measures to ensure the protection of the customer data. Genetic information is regarded as one of the most sensitive as the information is unique and it cannot be altered in case of exposure or abuse. Consequently, any security breach of such information may have long term privacy consequences to the victims.

2.2 Nature of Data Breach

The 23andMe security breach that happened in 2023 was a massive data breach that revealed personal and genetic data of millions of users all over the globe. The data breach was initially publicly noticed on 1 October 2023, when one user wrote on Reddit that they accessed 23andMe user data successfully and sold the information online. The post contained the sample records supposed to be in the company database which cast doubts on the possibility of customer accounts being compromised. Once a company employee discovered the post, 23andMe initiated an internal investigation to confirm the statement and find out whether its systems were compromised.

On 5 October 2023, the company established that the breach resulted due to credential stuffing attack, which is a prevalent cyber-attack technique that attacks user authentication systems. Credential stuffing is a technique whereby the attacker takes the usernames and passwords that have already been stolen through other unrelated data breaches and tries to log in to accounts on other platforms. Since most individuals use the same logging information on various Internet services, attackers can access the accounts in case the information is similar. The attack is often automated and in a relatively short period of time, thousands of attempts to log in may be made (Parsons, n.d.).

In 23andMe, attackers were able to log into some of the user accounts using the valid credentials they had gained in earlier attacks. When they got access, the attackers could access and download any information stored in those accounts. Approximately 14000 user accounts were directly impacted by the breach. Nevertheless, since the platform has a DNA Relatives feature that permits users to add and exchange information with genetic relatives, the attackers could gain access to other profile information of other users who had a DNA Relatives connection with the feature. Consequently, millions of people around the globe had their information at risk of being accessed through the accounts that were breached (23andMe, 2023).

The information that could have been accessed was the names, profile, ancestry reports and other personal information stored in the platform. It was also later reported that raw genetic data of certain users could have been accessed. Due to the fact that genetic information is both sensitive

and individualistic to a person, the disclosure of such data poses high risks to privacy and potential risks in the long term.

2.3 Timeline of the Data Breach

The 2023 data breach timeline presents a chronological summary of the most significant events surrounding the case, such as the discovery of the breach, the actions that were taken by the company to address the situation, and the regulatory investigations. The order of events is significant in the analysis of digital evidence since it assists the investigator in reorganizing the unfolding of the incident and when there was unauthorized access and how well the organization responded in time to the incident. The table below outlines the key events in connection with the breach, according to the publicly stated reports by regulators and the company (OPC, 2025).

Table 1.0 Timeline of the data breach

Date	Key Event Description
1 October 2023	On Reddit, one user said he had accessed the systems at 23andMe and sold the data of customers on the internet. The post contained sample data that supposedly were taken on the platform of the company.
5 October 2023	Upon researching the Reddit claim, 23andMe themselves verified that attackers had indeed conducted a credential stuffing attack on some of its user accounts.
6 October 2023	The breach was publicly announced on the website of the company and the company confirmed that it happened when credential stuffing was performed with the help of previously hacked login credentials.
9 October 2023	As a security measure, 23andMe shut down all active user accounts on its site.
10 October 2023	The breach was informed to customers through email. The users had to change their passwords and were advised to use multi-factor authentication (MFA).
15 October 2023	The first breach report submitted by 23andMe to the UK Information Commissioner Office (ICO).
18 October 2023	The company filed its initial breach report with the Office of the Privacy Commissioner of Canada (OPC).
December 2023	Later reports also led to the realization that some 6.9 million users were

	infected around the world including some raw DNA information being exposed.
10 June 2024	There was a joint investigation conducted in privacy practices and security protection of 23andMe that was announced publicly by the ICO and OPC.

2.4 Impact of the Data Breach

This 2023 23andMe data breach had a major impact on the company and the affected users because of the magnitude of the incident and sensitivity of the information involved. The company claimed that the breach had impacted millions of people around the world after the investigation commenced. Initial calculations estimated that the information of approximately 1.1 million users was viewed, but later research showed that the amount of users impacted had reached about 7 million users worldwide (ICO Report, 2025).

A significant issue that was raised by professionals and regulators was the nature of data that was compromised during the breach. The hacked data was customer profile information including names, family tree data and other personal data that was contained in the customer accounts. In other instances, attackers could also gain access to raw genetic data, also referred to as genotype information. Genetic information cannot be altered or replaced once brought to light like in the case of passwords or financial information. Since DNA has a unique biological information about a person and his/her relatives, the abuse of this data may result in a long-term risk of privacy and possible discrimination issues.

The intrusion also resulted in the company losing reputation. Organizations that handle sensitive health and genetic information especially need trust. Due to the incident, there were numerous users, who were voicing their concerns regarding the safety of their personal information and the implementation of the necessary security measures. Cybersecurity specialists observed that the cases related to genetic information might have far-reaching consequences since people might be unsure about the future safety of their biological details when it was already leaked (Parsons, n.d.) Besides reputational effects, the breach led to regulatory inquiries and legal repercussions. In Canada and the United Kingdom, privacy regulators initiated a joint investigation to determine whether the company had taken proper security measures to safeguard the information of its

customers and whether it had met its respective data protection regulations like the UK General Data Protection Regulation (UK GDPR) and the Personal Information Protection and Electronic Documents Act (PIPEDA) in Canada (ICO Report, 2025).

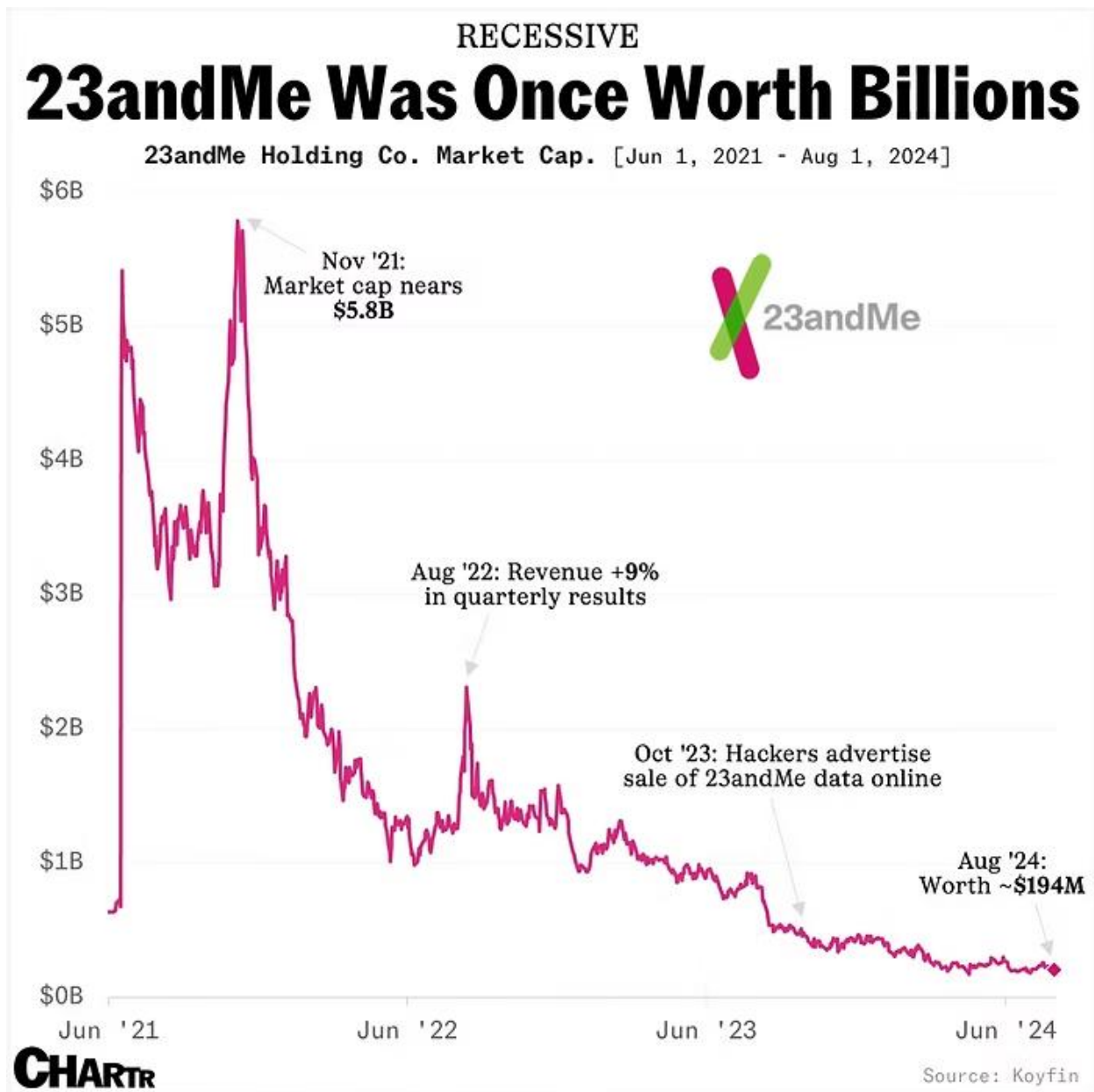


Figure 2.0 Market Cap of 23andMe (Sekurno, 2025)

3.0 Scope and Objectives

3.1 Scope

3.1.1 In Scope

The scope of this digital forensic investigation report includes :

1. Technical analysis of the 2023 credential stuffing attack affecting customer accounts.
2. Development of the incident timeline based on publicly available information.
3. Identification of the attack vector, authentication weaknesses exploited, and affected digital assets.
4. Examination of categories of compromised data, including :
 - a. Personally Identifiable Information (PII)
 - b. Account metadata
 - c. Profile and ancestry-related data
5. Documentation of forensic processes for :
 - a. Evidence identification
 - b. Evidence collection
 - c. Evidence acquisition
 - d. Evidence preservation
 - e. Chain of custody procedures
6. Legal discussion of relevant proceedings and implications of cybersecurity governance.
7. Case relevance to Malaysia cybercrime law.

3.1.2 Out of Scope

1. Direct forensic investigation of 23andMe's internal system.
2. Conduction of penetration testing to the company's infrastructure.
3. Determination of civil or criminal liability.
4. Calculation of financial impact caused by the incident.

3.2 Objectives

The following are the objectives of this forensic investigation :

1. To determine the attack vector used to gain unauthorized system access.
2. To identify limitations in authentication and intrusion detection that enabled large-scale data leakage.
3. To demonstrate proper digital evidence handling procedures, such as identification, collection, acquisition, preservation, and chain of custody documentation.
4. To analyse potential forensic artifacts that would be significant in court proceedings.
5. To ensure the digital evidence's integrity and admissibility.
6. To reveal the cybersecurity weaknesses from the incident and legal implications.
7. To discover the relevance of this case within the context of Malaysia cybercrime legislation and digital evidence law.
8. To organize and present the investigation results in a professional way for submission in court proceedings.

4.0 Legal Discussions

4.1 Legal Basis for the Forensic Investigation

It is mandatory to establish the legal right to search and the authority to collect evidence before conducting a digital forensic audit. For investigations revolving 23andMe, the legal basis is in three main areas:

4.1.1 International Regulatory Authority

Since 23andMe operates globally, the investigation is legally driven by international policies. The UK Information Commissioner's Office, also known as ICO, has the power under the Data Protection Act 2018 to investigate if 23andMe failed to protect the sensitive genetic data of UK citizens. Under PIPEDA, Office of the Privacy Commissioner of Canada also known as OPC has the legal right to audit 23andMe's security practices following the 2023 breach.

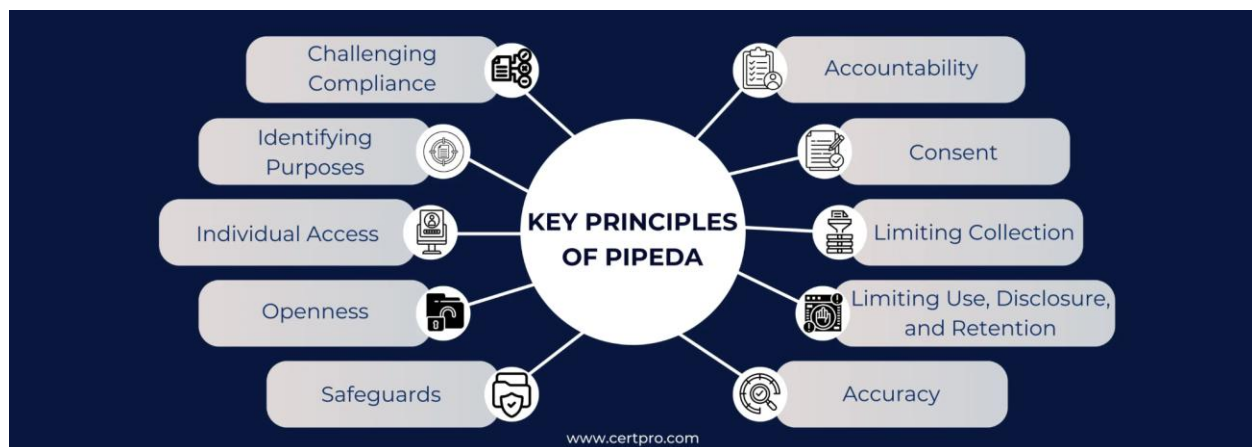


Figure 3.0 Principles of PIPEDA

4.1.2 Ongoing Court Cases

The evidence gathered is intended for use in active legal battles.

Class Action Lawsuit: There is a large, combined lawsuit in a California court called In re: 23andMe, Inc. Customer Data Security Breach Litigation which provides the legal reason for us to examine how the company handled the breach.

Bankruptcy Protection: When 23andMe filed for bankruptcy in March 2025, the court appointed a Consumer Privacy Ombudsman. This person's job is to oversee the "Chain of Custody" and make sure sensitive genetic records aren't sold off or misused while the company deals with its financial problems

4.1.3 Forensic Standards for Expert Testimony

To make sure this report is accepted in a court of law, all the procedures followed ISO 27037 standards. This provides the legal foundation for our role as Digital Forensic Experts, ensuring that the low-and-slow attack analysis that was provided is considered expert testimony rather than just an opinion.

4.2 Compliance with Global Data Protection Standards

Specific data protection laws governed 23andMe's obligations during the breach. Because the company manages irreversible genetic information, it is held to a higher standard of care than typical digital services.

4.2.1 The Security Principle and Duty of Care

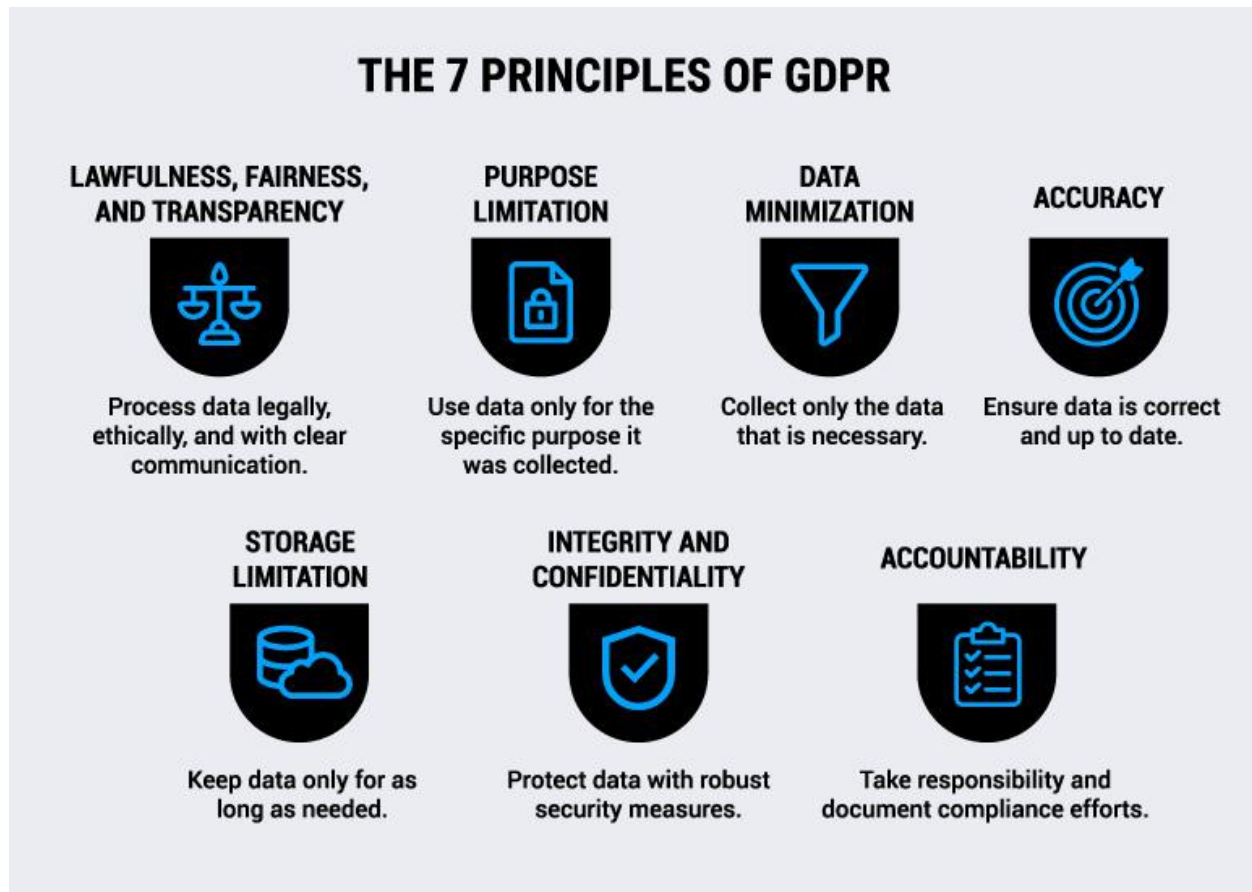


Figure 4.0 Principles of UK GDPR

Under laws like the UK GDPR, organizations must implement security safeguards that are strong enough to protect the specific type of data they hold.

- **Failure of Duty:** The investigation by the UK Information Commissioner's Office (ICO) found that 23andMe failed this duty by not making Multi-Factor Authentication (MFA) mandatory before the breach.
- **Weak Protections:** The company allowed millions of records to be protected by simple passwords that did not meet modern security standards, making it easy for attackers to use "credential stuffing" to get in.

4.2.2 Breach Notification and Tracking

Data protection laws require companies to detect and report breaches without undue delay.

- **The Detection Gap:** 23andMe had a five-month gap from April 2023 to October 2023 where they did not realize attackers were inside their systems.
- **Monitoring Failures:** Regulators found that the company's system for flagging unusual activity was not effective, which is a violation of the legal requirement to maintain ongoing confidentiality and integrity of user data.

4.2.3 Special Category Data

Genetic data is classified as Special Category Data because it is uniquely identifying and impacts not just the user, but their biological relatives.

- **Irreversibility:** Unlike a credit card number that can be changed, your DNA is permanent; once it is leaked, the privacy risk lasts a lifetime.
- **The Relatives DNA Risk:** Because of how 23andMe links users, a single compromised account allowed attackers to see the profile information of thousands of other relatives who was never even gotten hacked themselves.

4.3 Admissibility of Digital Evidence in Malaysia

Digital evidence found in the 23andMe breach, like login records and server logs, must meet strict legal criteria to be treated properly in a Malaysian court. To make sure our evidence is winnable and accepted by a judge, we must follow the Evidence Act 1950 (EA 1950).

4.3.1 Proving the Evidence is Real (Section 90A)

In Malaysia, for a computer-generated document like a log file to be used as evidence, the law requires us to prove it was produced by the computer during its normal daily work. The Section 90A Certificate states that the most important step is providing a signed certificate from the person in charge of the computer system. This certificate confirms that the logs were created during the ordinary course of use. Once we provide this certificate, the court will legally assume the computer was working correctly at the time the logs were made, unless someone can prove otherwise.

4.3.2 Using Expert Opinions (Section 45)

Since technical logs can be hard to understand, the court allows Expert Witnesses to explain them. An expert witness will say, we would use Section 45 to explain technical details, such as how the low-and-slow attack worked and why the system didn't catch it sooner. Furthermore, to make our expert opinion more reliable, we show the court that we followed global rules like ISO 27037 to keep the evidence safe and unchanged.

4.3.3 How Much Weight Does the Evidence Have? (Section 90B)

Even if the evidence is accepted, the judge has to decide how much to trust it. Under Section 90B, the court looks at whether the information was handled carefully and if there was any reason for someone to fake the data. The fact that 23andMe took five months to notice the breach might be used by the defence to argue that the logs are not fully reliable because the system's monitoring was weak.

4.4 Legal Mapping to Malaysian Cyber Laws

Technical actions of the hackers match specific crimes under the Malaysian Computer Crimes Act 1997 (CCA 1997). This mapping shows how the 23andMe breach would be handled as a criminal case in Malaysia.

4.4.1 Unauthorized access to computer material (Section 3)

The primary offense in this case is the unauthorized access to 23andMe user accounts.

- **The Act:** Attackers used stolen credentials from previous unrelated breaches to log into 18,450 accounts without permission.
- **Legal Application:** Under Section 3, a person is guilty if they cause a computer to perform a function with the intent to secure access to data, knowing that access is unauthorized.
- **Evidence Connection:** The use of automated Hydra scripts to bypass authentication qualifies as intentional unauthorized access.

4.4.2 Unauthorized access with intent to commit or facilitate commission of further offence (Section 4)

The breach is more serious because the access was used to enable further criminal activity.

- **Data Scraping:** After gaining access to 14,000 accounts, profile data for 6.9 million additional users via the DNA Relatives feature were stolen.
- **Fraudulent Intent:** Exfiltrating Specially Curated Lists based on ethnicity (such as Jewish and Chinese populations) to be sold on the Dark Web suggests an intent to cause fraud or targeted harm.
- **Legal Application:** This intent to commit a further offense elevates the severity of the charge under Section 4.

4.4.3 Unauthorized modification of the contents of any computer (Section 5)

Any alteration of account or system data during the breach falls under this category.

- **Account Manipulation:** Any change to security settings or passwords by the threat actors to maintain control over the accounts constitutes unauthorized modification.
- **System Interference:** The massive surge of over 1 million successful logins on July 6, 2023, interfered with the normal performance of the authentication system, which can be argued as a modification of the system's operational state.

4.4.4 Abetments and attempts punishable as offences (Section 7)

These sections apply to those who assisted in the crime or its aftermath.

- **Dark Web Distribution:** Individuals handling the sale of the exfiltrated genotype data on forums like Breach Forums could be charged with abetment.
- **Attempt:** Any unsuccessful attempt to procure or sell this data in Malaysia remains a punishable offense under Section 7.

4.5 Evidence Integrity and Forensic Standards

Technical steps were taken to ensure that the evidence is reliable and has not been tampered with. Following these standards is essential for the report to be accepted as professional "Expert Testimony" in a Malaysian court.

4.5.1 Adherence to ISO 27037 Standards

To make sure the findings are legally sound, this investigation followed the ISO 27037 international guidelines for handling digital evidence.

- **Identification:** Potential evidence was identified by monitoring Dark Web forums like Hydra and BreachForums and analysing 23andMe's internal server logs for unusual spikes in traffic.
- **Acquisition:** We used specialized tools and write-blockers to collect data without changing any of the original timestamps or file information.
- **Preservation:** The data was frozen by resetting all user passwords and temporarily disabling high-risk features to stop the attackers from causing more damage while collecting evidence.

4.5.2 Cryptographic Verification

To prove to the court that no one has changed the evidence since it was collected, we use a process called hashing. Every log file and piece of evidence was given a unique digital fingerprint called a SHA-256 hash. If even one letter in a log file was changed, the hash would completely change, immediately alerting the court that the evidence is no longer authentic.

4.5.3 Chain of Custody Records

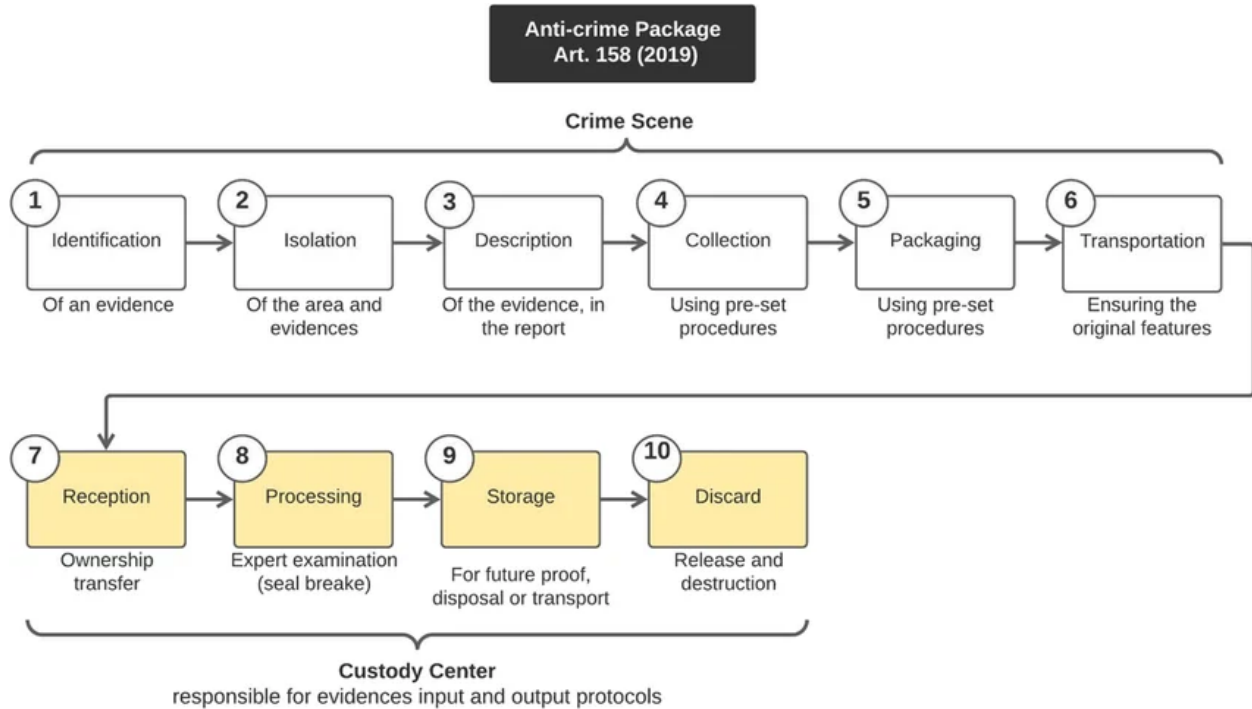


Figure 5.0 Steps of Chain of Custody According to the Anti-Crime Package

A Chain of Custody is a continuous log that tracks every person who has touched the evidence. A record of every instance of the evidence was moved or viewed by 23andMe staff, third-party experts like government regulators. After 23andMe filed for bankruptcy in March 2025, the Chain of Custody was expanded to include a court-appointed official to ensure the data remained safe during the company's financial transition.

Table 2.0 Chain of Custody Log for Digital Evidence

Evidence ID	Evidence Description	Source Location	Date & Time Collected	Collected By	Transferred To	Purpose
E-01	Authentication logs showing abnormal login attempts	23andMe Authentication Server	12 October 2023 - 10:15 AM	Digital Forensic Team	Lead Digital Investigator	Analysis of credential stuffing patterns
E-02	Web Application Firewall (WAF) logs indicating automated login attempts	23andMe Network Security System	12 October 2023 - 11:30 AM	Network Security Analyst	Digital Forensic Lab	Identification of attack timeline and IP patterns
E-03	DNA Relatives feature access records	23andMe Internal Platform Database	13 October 2023 - 09:45 AM	Database Forensic Specialist	Investigation Team	Determine scope of exposed user profiles
E-04	Raw genetic data export activity logs	23andMe User Data Management System	13 October 2023 - 11:10 AM	Data Security Analyst	Lead Investigator	Confirm unauthorized download of genotype data

E-05	Dark web marketplace listings of stolen datasets	Hydra Market & BreachForums	14 October 2023 - 14:20 PM	Cyber Threat Intelligence Analyst	Evidence Storage Repository	Verify exfiltration and sale of stolen data
E-06	Internal platform activity records related to compromised accounts	23andMe Internal Audit System	15 October 2023 - 10:05 AM	Digital Forensic Examiner	Regulatory Review Team	Reconstruct attacker activities

Table 2.1 Evidence Handling and Transfer Record

Date	Time	Evidence ID	Action	From	To	Signature
12 October 2023	10:20 AM	E-01	Evidence Collected	Authentication Server	Digital Forensic Team	DF-01
12 October 2023	11:45 AM	E-02	Evidence Collected	WAF System	Network Security Analyst	NSA-02
13 October 2023	10:00 AM	E-03	Evidence Collected	Platform Database	DB Forensic Specialist	DFS-03

13 October 2023	11:30 AM	E-04	Evidence Collected	Data Management System	Data Security Analyst	DSA-04
14 October 2023	14:35 PM	E-05	Evidence Collected	Dark Web Sources	Cyber Threat Intelligence Analyst	CTI-05
15 October 2023	10:20 AM	E-06	Evidence Collected	Internal Audit System	Digital Forensic Examiner	DFE-06
16 October 2023	09:00 AM	All	Evidence Transfer	Investigation Team	Digital Evidence Storage Facility	DF-Lead

4.5.4 Professionalism and Court Readiness

By following these strict rules, we ensure the report meets the high standards of professionalism expected by the Malaysia Court of Justice. Diagrams and clear language were used so that judges and lawyers, who may not be tech experts can easily understand the evidence. These integrity checks prevent the defence from claiming the data was faked or corrupted, putting the case in a strong position for a successful prosecution.

5.0 Forensics Methodology

Adherence to ISO 27037 and SWGDE standards ensures all evidence was systematically identified, collected, and preserved to maintain its admissibility in court.

5.1 Forensic Tools and Techniques

Specific hardware, software and analytical techniques were utilized by the investigative team. These include network log analysis methods used to detect the credential stuffing attack and also alongside specialized forensic software for secure data acquisition and cryptographic verification.

Table 3.0 Forensic Toolset Used in the Investigation

Tool	Purpose in Investigation
Splunk Enterprise Security	Used to analyze authentication and server logs to detect abnormal login patterns related to credential stuffing attacks (Splunk, n.d.).
Wireshark	Network protocol analyzer used to examine suspicious network traffic and identify malicious IP address activity (Wireshark, n.d.).
FTK Imager	Used to create forensic copies of system logs and digital evidence without modifying the original data (BINUS UNIVERSITY, 2023).
Autospy Digital Forensic Platform	Used to analyze collected digital artifacts and reconstruct attacker activity from system logs.
SHA-256 Hashing Algorithm	Used to generate cryptographic hash values to verify the integrity and authenticity of collected digital evidence.
Maltego	Used to correlate threat intelligence such as attacker IP addresses and related infrastructure.
DarkOwl/ Recorded Future	Used to monitor dark web marketplaces and identify datasets related to the stolen 23andMe data.
MySQL Workbench	Used to extract and analyze database records related to the DNA relatives future and compromised user accounts.

Table 3.1 Forensic Technique Used in the Investigation

Technique	Description	Purpose in Investigation
IP Address Identification and Log Analysis	Examination of server access logs and HTTP header information to identify suspicious login attempts and anomalous IP addresses.	Identify attacker infrastructure involved in credential stuffing activities.
Time-Window Event Correlation	Cross-referencing login events from malicious IP addresses with subsequent genetic data download events within a defined time window.	Attribute unauthorized data downloads to threat actor activity.
Bespoke Log Analysis	Analysis of a custom-built download logging system used by the platform to track raw genetic data exports.	Investigate data exfiltration activities despite limitations in standard server logs.
Network Traffic Pattern Analysis	Examination of login request behaviour and automated traffic patterns associated with credential stuffing tools.	Distinguish automated attacks from legitimate user activity.
Dark Web Intelligence Analysis	Monitoring underground cybercrime forums and marketplaces for stolen datasets linked to the breach.	Confirm that the compromised data had been distributed within the cybercrime ecosystem.

5.2 Process of Acquiring, Preserving, and Analysing Digital Evidence

Step-by-step forensic procedures executed during the investigation of the 23andMe credential stuffing attack adhere to ISO 27037 and SWGDE guidelines to ensure all digital artifacts remain court admissible.



Figure 6.0 Digital Evidence Collection Process

5.2.1 Acquiring Digital Evidence

The primary goal during the acquisition phase was to safely extract server logs and compromised account data without altering the original systems. Because the attack was ongoing, investigators prioritized the live system extraction of volatile memory and active network session data before they could be overwritten. To ensure the original data remained untouched, forensic experts utilized industry-standard tools, such as FTK Imager to create exact bit-for-bit copies of the Web Application Firewall (WAF) logs, authentication databases and DNA Relatives access records. During this imaging process, hardware and software write-blockers were strictly deployed to guarantee that investigators did not accidentally modify any file metadata, such as last accessed or modified timestamps.

5.2.2 Preserving Digital Evidence

Preservation efforts focused on securely freezing the compromised environment and safeguarding the collected information to prevent tampering or further data loss. To stop the ongoing breach and preserve the current state of the database, 23andMe initiated an environmental freeze by mandating a global password reset on 10 October 2023 and temporarily disabling the self-service Raw Genetic Data download feature on 2 November 2023. Immediately upon the acquisition of data, every log file and forensic image was assigned a SHA-256 cryptographic hash. This hashing process created a digital seal to legally prove that the evidence remained unchanged from the exact moment of collection. Furthermore, a strict administrative Chain of Custody (CoC) log was maintained to document every transfer of the hashed evidence between 23andMe's internal teams, third-party forensic specialists and international regulatory bodies.

5.2.3 Analysing Digital Evidence

The analysis phase involved parsing the acquired logs to reconstruct the threat actor's movements and accurately determine the scope of the exfiltrated data. Investigators parsed the server access

logs to identify the attacker's IP addresses by specifically filtering for anomalous login signatures, such as successful logins where the HTTP referrer field was empty and a specific customer agent string was used. To identify how the 6.9 million profiles were scraped, the forensic team queried the logs for malicious IP addresses actively targeting a specific system endpoint containing the unique signature /p/1/. During this phase, the forensic team encountered a technical limitation where a bug in a bespoke system log incorrectly recorded the internal loopback IP address (127.0.0.1) instead of the downloader's actual IP during Raw Genetic Data downloads. To bypass this issue, investigators applied a time-window event correlation technique, cross-referencing the login history of compromised accounts and attributing any Raw Genetic Data download to the threat actor if it occurred within a six-hour window following a login from a known malicious IP.

6.0 Evidence Collection

Chronology of the data breach at 23andMe

April 2023: The hacker began their credential-stuffing attack, before carrying out their first period of intense credential-stuffing activity in May 2023.

July 2023: The hacker used a computer program to log into a free account with no associated [DNA](#) sample over a million times throughout the course of a single day. This was part of an unsuccessful attempt to initiate “profile transfers.” Due to this intense volume of logins during the course of a single day, 23andMe’s platform stopped working and their users were unable to access the platform.

Later in July 2023: There was a further attempt by the hacker to initiate profile transfers in 400 separate accounts. Despite 23andMe investigating this incident at the time, it failed to detect that this was part of a larger ongoing data breach.

August 2023: A claim of data theft affecting over 10 million users received via the 23andMe customer service portal and repeated on Reddit was dismissed as a hoax by 23andMe.

September 2023: The hacker carried out a second intense period of credential stuffing activity.

October 2023: The hacker advertised the stolen data for sale on Reddit. 23andMe further investigated the incident and confirmed that a data breach had occurred.

June 2024: The [OPC](#) and the [UK ICO](#) [announced a joint investigation into the 23andMe data breach](#), underlining the regulators’ commitment to collaborate on protecting the fundamental right to privacy of individuals across jurisdictions.

March 2025: The [OPC](#) and the [UK ICO](#) issued their provisional findings to 23andMe and provided the company with an opportunity to respond to the preliminary report.

March 2025: 23andMe Holding Co. and certain of its subsidiaries, including 23andMe, filed for Chapter 11 Bankruptcy under the [US](#) Bankruptcy Code.

April 2025: The Offices [wrote to the US Trustee overseeing 23andMe’s bankruptcy proceedings](#) to emphasize that personal information relating to individuals located in Canada and the [UK](#) must be handled in compliance with our respective data protection laws.

June 13, 2025: 23andMe announces that it has entered into an agreement with the TTAM Research Institute for the sale of substantially all of 23andMe’s assets.

June 17, 2025: Commissioners Dufresne and Edwards hold a joint press conference to [announce the findings of the 23andMe investigation](#).

Figure 7.0 Chronology of DataBreach at 23andMe

6.1 Sources of Digital Evidence

6.1.1 Network Authentication and WAF Logs

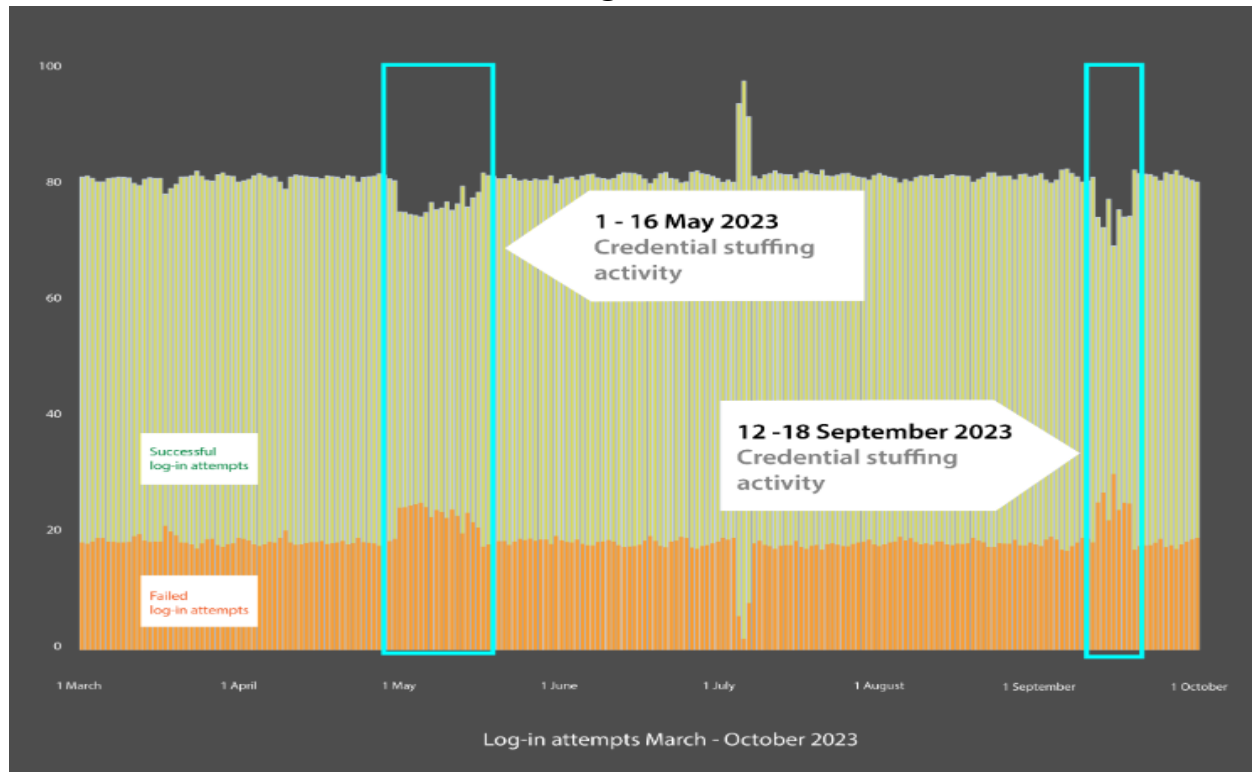


Figure 7.1 Login attempts to the 23andMe platform

From 29 April 2023 to September 2023 the Digital forensic analysis of web application firewall (WAF) logs showed that there was a persistent “low and slow” credential stuffing attack. The attacker used stolen credentials from previous unrelated breaches to gain access to 18,450 Accounts.

6.1.2 DNA Relatives Profiles

Table 4.0 Types of Data Exposed in the 23andMe Data Breach

DNAR Profiles, Ancestry Reports and Family Tree Profiles Number* of affected individuals reported by 23andMe			
Type of compromised PI	Canada	UK	Worldwide
DNAR Profiles	244,583	120,031	5,497,376
Ancestry Reports 19	245,208	120,504	5,512,131
Family Tree Profiles	74,282	35,561	1,468,791
<i>* The DNAR Profiles and Family Tree Profiles groups are mutually exclusive, while the DNAR Profiles and Ancestry Reports are not mutually exclusive.</i>			

The evidence confirms that the “DNA Relatives” opt-in feature allowed the threat actor to scrape data for approximately 6.9 million users globally, despite only a small fraction of accounts being compromised.

6.1.3 Exfiltrated Specially Curated List

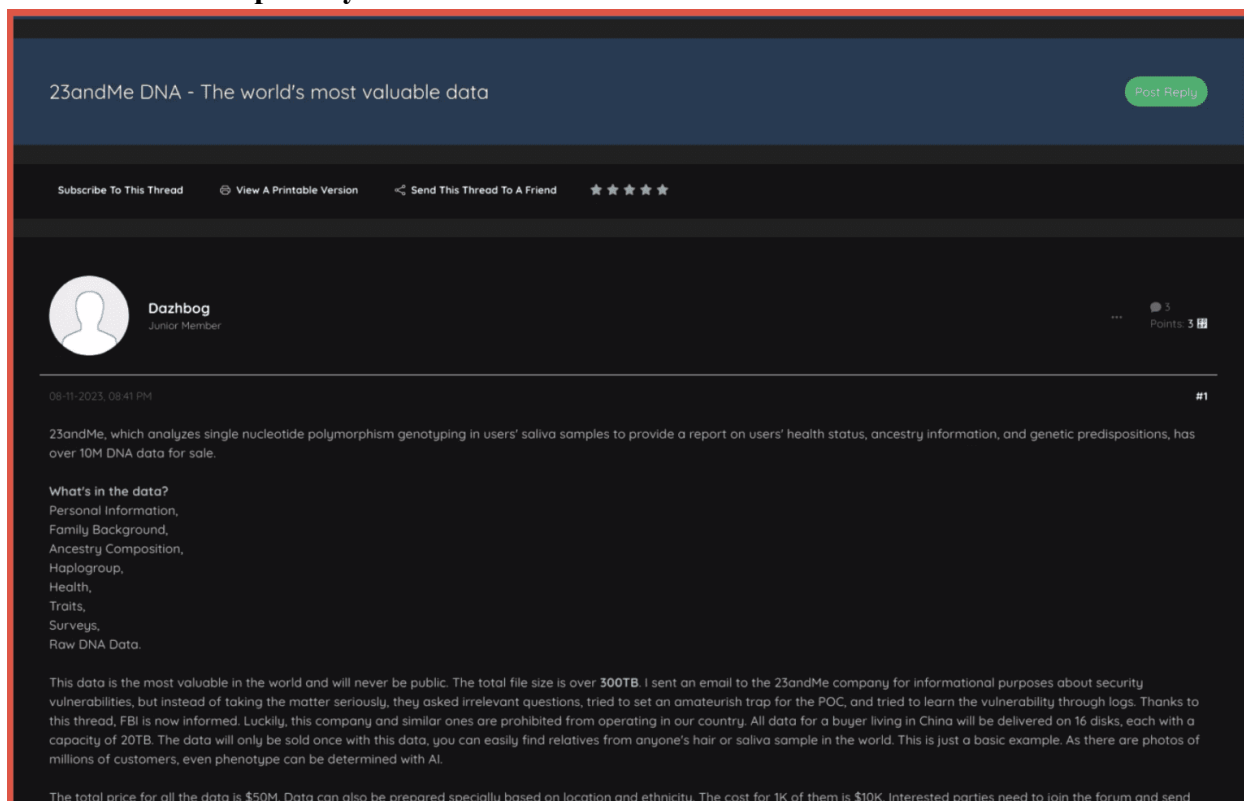


Figure 7.2 The Hydra Post

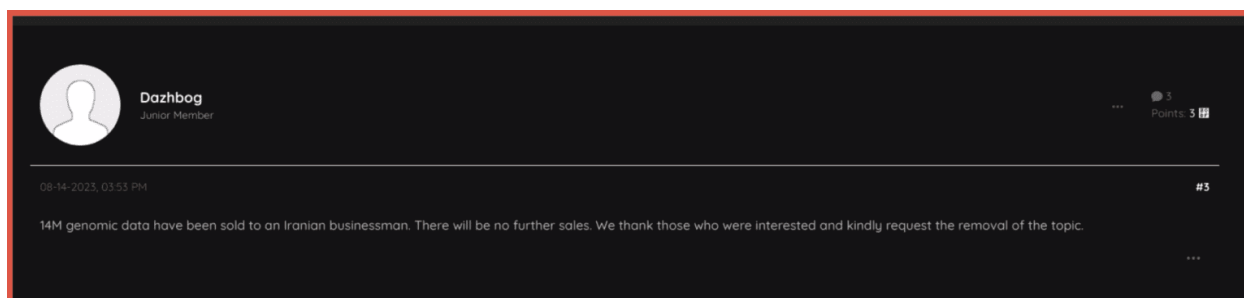


Figure 7.2.1 Hydra Post dated 14 August 2023

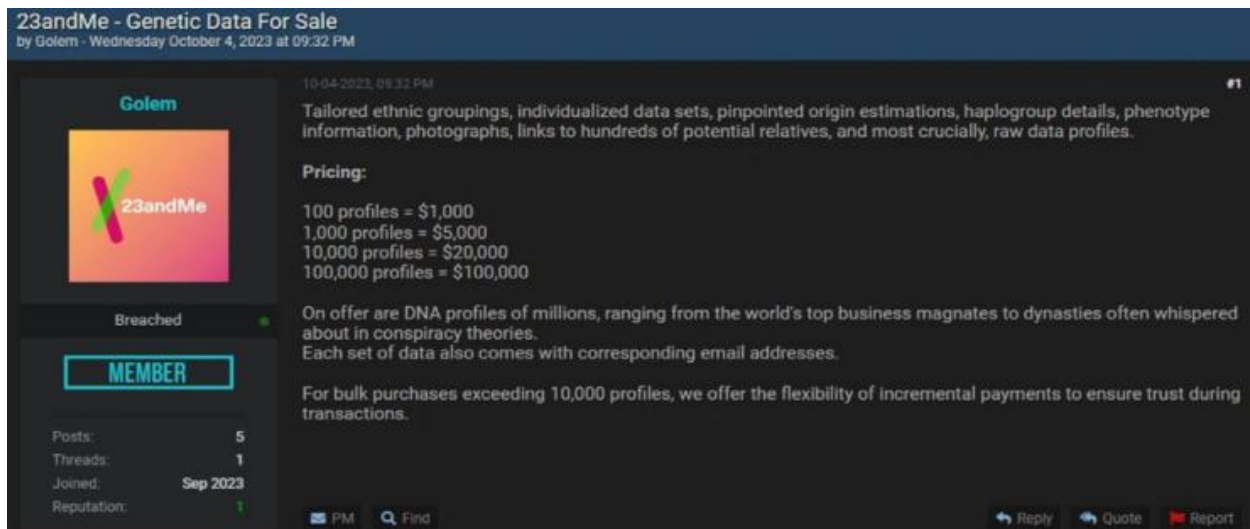


Figure 7.3 The BreachForums post dated 4 October 2023

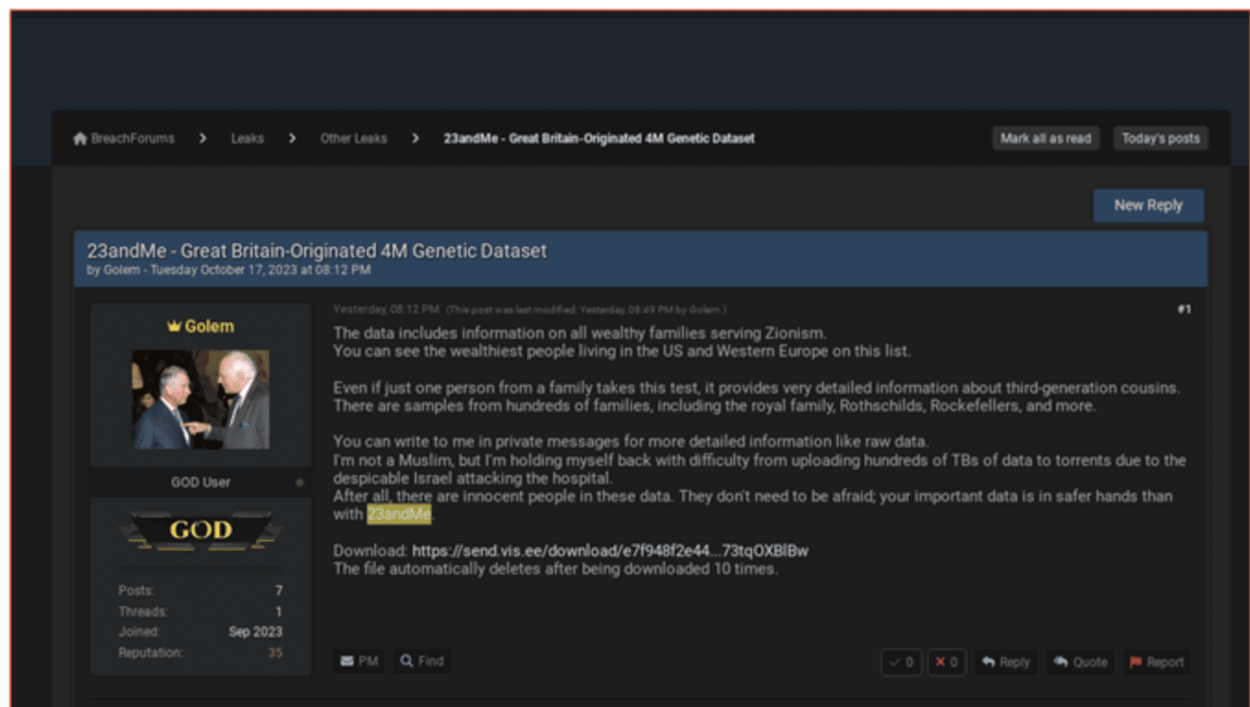


Figure 7.3.1 The BreachForums Post Dated 17 October 2023

Evidence is stolen and sold on Dark Web listing on forums such as Hydra Market and BreachForum. These listings are curated by ethnicity, targeting Jewish and Chinese.

6.1.4 Raw Genotype Data Files

Table 4.1 Statistics on Credential-Stuffed Accounts Reported in the 23andMe Data Breach

Credential Stuffed Accounts Number of affected individuals reported by 23andMe			
Stuffed Accounts	Canada	UK	Worldwide
Total:	769	611	18,222
Type of compromised P.I.	Canada	UK	Worldwide
Raw DNA (downloaded)	1*	0	18*
Raw DNA (accessed/browsed) 22	2	2	49
Health Reports	413	320	8,217
Self-reported Health Condition	2	3	63
<i>* As detailed in paragraph 33 below, these numbers were amended following further analysis by 23andMe.</i>			

Forensic evidence proves that for some compromised accounts, the threat actor utilized the platform native download function to exfiltrate highly sensitive raw DNA data.

6.2 Procedures Followed During Evidence Collection

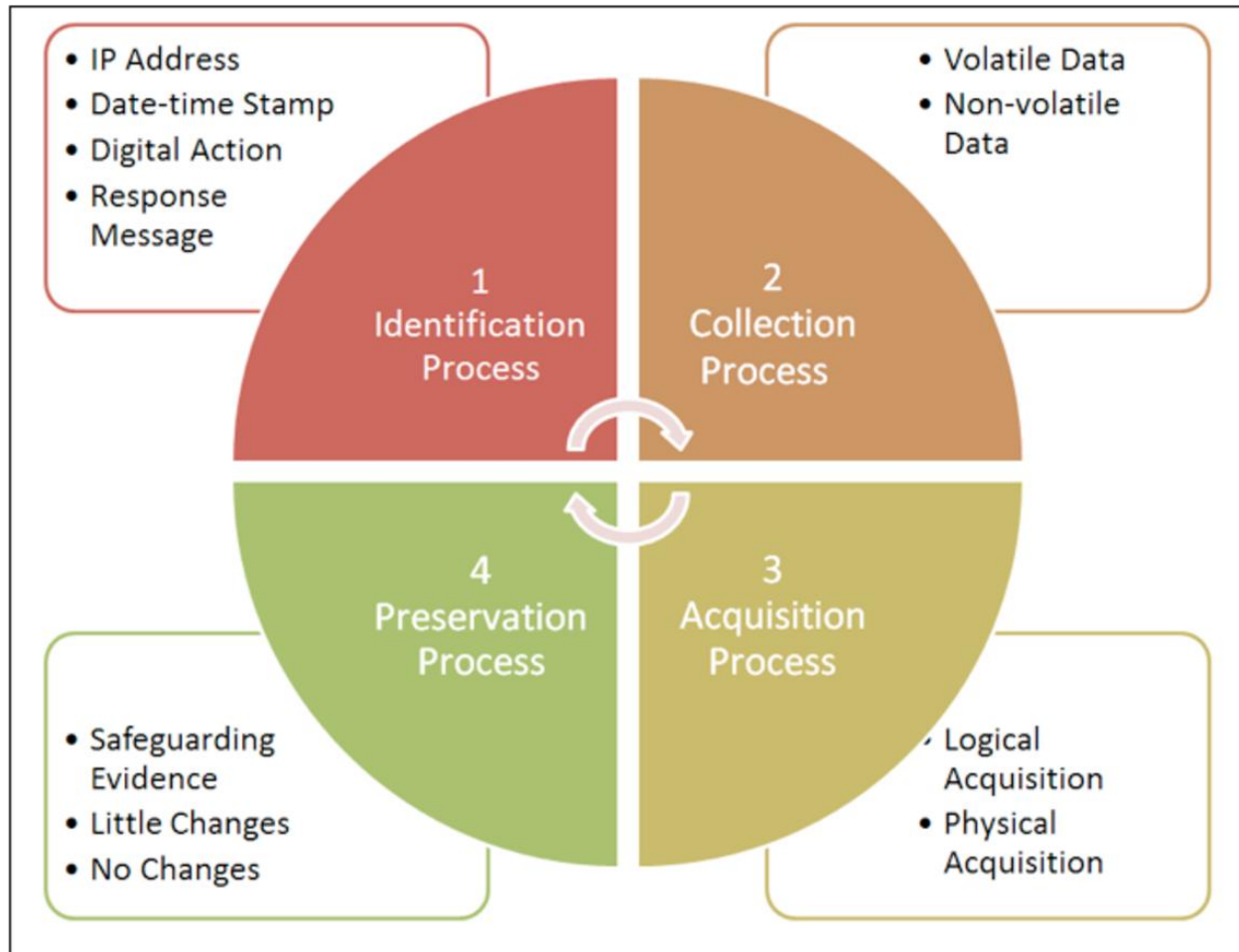


Figure 8.0 Process Flow of Handling Digital Evidence

Step 1: Identification (ISO 27037 Stage 1)

This stage involves the search for and recognition of potential digital evidence.

- **External Intelligence Discovery:** The identification process was triggered on October 1, 2023, following the discovery of unauthorized data advertisements on Reddit and BreachForums.
- **Internal Log Recognition:** Forensic teams identified a massive, unflagged anomaly in the authentication logs from July 6, 2023, where successful logins peaked at over 1 million in a 24-hour period.

Step 2: Collection (ISO 27037 Stage 2)

This stage involves the process of gathering digital artifacts from their original location.

- **Targeted Data Gathering:** Collection focused on the DNA Relatives (DNAR) and Family Tree feature logs, which served as the primary source for the unauthorized scraping of 6.9 million user profiles.
- **Threat Actor Artifacts:** Investigators recovered "Specially Curated Lists" from Dark Web repositories (Hydra Market) to verify the categories of sensitive information being sold.

Step 3: Acquisition (ISO 27037 Stage 3)

This stage involves obtaining digital evidence without altering the original source.

- **Bit-Stream Imaging:** Third-party specialists (Mandiant) performed bit-stream imaging of the production server environment to capture a forensically sound copy of the WAF and Network Authentication logs.
- **Integrity Protection:** In accordance with ISO recommendations, write-blockers were utilized during the acquisition process to prevent any modification of original metadata or timestamps.

Step 4: Preservation (ISO 27037 Stage 4)

This stage ensures the maintenance of the integrity and custody of the evidence.

- **Cryptographic Verification:** Every seized artifact and forensic image was assigned a SHA-256 cryptographic hash at the point of acquisition to create a "digital seal".
- **Environmental Freeze:** On October 10, 2023, 23andMe initiated a global password reset and disabled high-risk features (Raw Data Download) to "freeze" the data environment and preserve its current state for the joint investigation.

6.3 Chain of Custody (CoC) Requirements

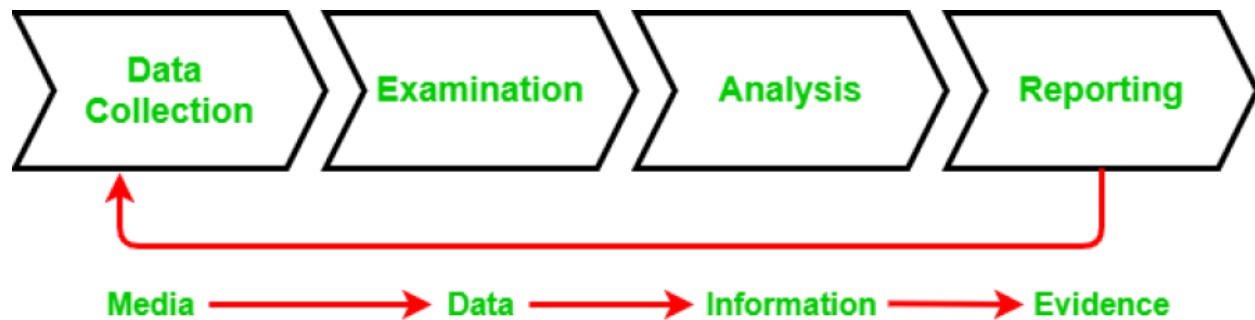


Figure 9.0 Chain of Custody Process Flow

- **Cryptographic Verification (Technical CoC):**
 - To ensure data integrity, every log file and database export was assigned a SHA-256 cryptographic hash at the point of collection.
 - This "digital seal" allows investigators to prove that the evidence remained identical and untampered with throughout the two-year investigation period (2023–2025).
 - Any modification to the underlying data would result in a different hash value, immediately alerting the UK ICO or Canadian OPC to a breach in the chain of custody.
- **Custodial Transfer and Access Logs (Administrative CoC):**
 - A comprehensive Chain of Custody log was maintained to document every instance the evidence was accessed, moved, or transferred between 23andMe IT, third-party forensic firms (Mandiant), and international regulators.
 - Each entry in the log included the name of the individual, the date/time of access, and the specific purpose for handling the evidence.
- **International Handover Protocols:**
 - Specific protocols were followed for the secure transfer of digital artifacts between the UK ICO and the Canadian OPC.
 - This ensured that the evidence collected in one jurisdiction remained legally valid for joint analysis and systemic security audits performed by both commissions.
- **Bankruptcy Custodial Oversight (March 2025):**

- Due to 23andMe's March 23, 2025 bankruptcy filing, the chain of custody was extended to include the US Trustee.
- A court-appointed Consumer Privacy Ombudsman was integrated into the CoC to oversee and protect sensitive genetic data while the company's assets were being reviewed for potential sale.

7.0 Data Preservation Techniques and Challenges

7.1 Data Preservation Techniques

Forced Global Remediation: Following the identification of the breach, 23and Me froze the compromised environment on 10 October 2023, by implementing mandatory password reset for its entire user base of 14 Million Users. This is critical to terminate any unauthorized sessions and invalidate stolen credentials used by attackers during the five month breach period.

Suspension of High Risk Data Portability Feature: To ensure the integrity of user genetic information during forensic audit, 23andMe temporarily disabled Raw Data Download and DNA Relatives feature. This prevents the threat actor from scraping the profile data or exfiltrating sensitive raw genotype files while investigators perform bit-stream imaging of the production server.

Mandatory Multi-Factor Authentication (MFA) Implementation: Investigators found out that prior to the breach, MFA was merely an optional opt-in feature. As the primary preservation measure for the remaining database, 23andMe decides to do Mandatory MFA for all existing accounts. This preserved the long-term integrity of data, the joint investigation cited the delay in making this mandatory as a significant security deficiency

7.2 Preservation and Investigation Challenges

- **The "Low-and-Slow" Detection Gap:** A primary challenge was the five-month latency between the initial attack in April 2023 and its discovery in October 2023. Because the threat actor used a "low-and-slow" credential stuffing technique, the unauthorized logins mimicked legitimate user traffic and stayed below the company's automated alert thresholds. This resulted in the loss of some early-stage volatile log evidence that had already been rotated or overwritten by the time preservation began.
- **Absence of Specialized Incident "Playbooks":** The joint investigation revealed that 23andMe lacked a specific Incident Response Playbook designed to handle credential stuffing attacks. This led to a fragmented preservation process where investigators initially dismissed significant warning signs including a massive spike of over 1 million successful logins on July 6, 2023 as an isolated technical glitch rather than a systemic breach.
- **Immutability and Permanence of Genetic Evidence:** Unlike traditional computer crimes involving credit cards or passwords, the DNA data exfiltrated in this case is permanent and cannot be changed or reissued. This created an immense challenge for investigators; once the sensitive information was "scraped" and advertised on Reddit, the breach was irreversible, making the preservation of the remaining environment a high-stakes operation with no room for error.
- **Insolvency and Legal Chain of Custody:** The company's March 23, 2025, Chapter 11 bankruptcy filing introduced a unique legal hurdle for data preservation. Investigators had to ensure that the sensitive genetic database remained legally preserved and protected from unauthorized access or sale while the company's assets were managed by a US Bankruptcy Trustee.

8.0 Analysis and Findings

The analysis conducted in this section is based on the digital evidence that is collected and preserved that is described in **section 6.0 Evidence Collection**, that includes the authentication logs, Web Application Firewall (WAF) logs, dark web intelligence artifacts, and internal platform data records.

8.1 Authentication and Network Log

The evidence that was gathered during the investigation in relation to authentication and network logs shows that the 23andMe platform has experienced a long-term credential stuffing attack that lasted over a long period of time. Credential stuffing attacks are attempts to exploit pre-existing unrelated data breach-acquired username and passwords on multiple different platforms through automated access to user accounts (Holthouse, Owens & Bhunia, 2025).

The Web Application Firewall (WAF) logs of the log-in activity (Figure 7.1) indicate that there is a dramatic rise in authentication attempts during the period between April 2023 and September 2023. The attempts to log in were not only based on several geographically diversified IP addresses but also presented the patterns typical of automated programs instead of the human-generated ones.

Additional forensic analysis of the logs indicated that the threat agents used a low and slow attack strategy. In this method, one tries to make a number of login attempts that are slow enough to evade automated detection limits so that the attacker does not cause the intrusion detection systems of the company to go off. Since the attempts to log in were carried out using valid credentials that were gained in previous breaches, the activity was very similar to an authentic user authentication behavior and was thus left unnoticed over a few months (ICO Report, 2025).

The findings of the investigation made by regulatory authorities revealed that around 18,450 accounts were accessed by using stolen credentials in the course of the attack. This is evidenced by the fact that valid authentication credentials were employed to access the system and so, the attackers did not use system vulnerabilities but instead, used user authentication vulnerabilities.

8.2 DNA Relatives Feature Exploitation

Among the most prominent results of the investigation is the abuse of the DNA Relatives feature of the platform. This aspect enables people who subscribe to the service to find and befriend other people with similar DNA analysis.

The material gained during the investigation proves that after attackers gained access to the compromised accounts of users, they could use the DNA Relatives option to see the information about other users who have similar DNA.

The types of data revealed by this facility are summarized in **Table 4.0**, which gives the type of user information available in the DNA Relatives system. The unsecured data had profile identifiers, family tree data, ancestry report and other personal profile information of the affected users.

The scale of the breach was greatly increased by the interconnectivity of the feature of DNA Relatives, even though the number of compromised accounts was relatively small. Having gained access to a limited number of accounts, attackers could gather the information on millions of other users that had joined the genetic matching network.

This feature was later verified by regulatory probes that the attackers had access to information of about 6.9 million users around the world (Office of the Privacy Commissioner of Canada, 2025). This observation shows that the characteristics of platform design that allow the sharing of user data can accidentally augment the magnitude of data disclosure in the event of a security breach.

8.3 Dark Web Intelligence

Further forensic evidence to back the findings of the investigation was derived in the dark web intelligence sources. Researchers found a number of online advertisements and postings that claimed to contain datasets that were a result of the 33andMe breach.

Such advertisements are illustrated in **Figure 7.2, Figure 7.2.1, Figure 7.3 and Figure 7.3.1** that present listings on underground cybercrime forums like Hydra Market and BreachForums. Such listing included sample records and promotion descriptions that indicated that the datasets were made of personal and genetic data taken out of 23andMe user accounts.

The advertised datasets that were analyzed showed that the stolen information was arranged into the curated lists which were divided according to the ethnicity and ancestry groupings. Certain databases were even sold as information pertaining to specific ethnic groups such as Jewish and Chinese ancestry.

The fact that these datasets were available on underground forums is a good indication that the attackers indeed stole the data off the platform and they tried to sell the stolen information in the black markets of cybercrime. The emergence of these listings also proves the fact that the breach was not limited to the unauthorized access and included intentional sharing of sensitive personal data.

9.0 Relevance to the Case

9.1 Network Authentication and WAF Logs

The authentication and Web Application Firewall (WAF) logs shown above in **Figure 7.1** give firsthand data on the credential stuffing attack that occurred on the 23andMe platform. These logs indicate that there are high automated login attempts, which have different IP addresses and a long duration. This is evidence that is applicable in the investigation since it shows that attackers were trying to infiltrate the platform with already stolen logins instead of taking advantage of the vulnerabilities in the platform itself. The unusual log in activity that includes multiple authentication and access points of the system located in different geographic areas is a clear indication of automated credential testing activity.

The logs would provide the investigators with a perspective on the main attacker in the context of the investigation and would enable them to determine the chronology of the unauthorized access to the user accounts. Such information will be critical in the process of knowing how the breach was initiated and why the attackers could spend many months without detection.

9.2 DNA Relatives Feature Data Exposure

The data established in Table 4.0 indicates the type of user information that might have been obtained using the DNA Relatives feature. This fact is very much applicable as it shows how the structure of the genetic matching system implemented on the platform allowed attackers to gather plenty of user data as soon as they could obtain limited access to a high number of accounts that had been compromised.

Although the attackers had directly accessed relatively few accounts, the interlinked nature of the DNA Relatives feature enabled them to access profile information of millions of other users who had signed up to the genetic matching network. Consequently, the breach impacted about 6.9 million users despite the fact that a minimal percentage of accounts were first infiltrated (Office of the Privacy Commissioner of Canada, 2025).

In the larger inquiry, this fact provides an explanation of how the intrusion started as a small scale account break and evolved into a massive data exposure event. It emphasizes how platform functionality and data sharing mechanisms may contribute to the effects of security incidents to a great extent.

9.3 Dark Web Marketplace Evidence

The dark web intelligence data in **Figure 7.2, Figure 7.2.1, Figure 7.3 and Figure 7.3.1** testify that the attackers exfiltrated and distributed the stolen data. The following screenshots depict advertisements of datasets that supposedly include the user information of 23andMe in underground cybercrime forums like Hydra Market and BreachForums.

The evidence can be used to study the case as it indicates that the breach had not only caused unauthorized access to the system but also led to the illegal disclosure of sensitive personal information. The fact that the stolen datasets were made available on cybercrime marketplaces implies that the hackers had a motive of making money out of the breach to sell the information to other malicious entities.

In a more investigative sense, the existence of these listings offers validation that the breach did not just have an internal implication on the organization in question. It confirms the fact that the information that was compromised had already been integrated into the cybercrime ecosystem and, possibly, it could be employed to commit identity theft, profiling, or other illegal activities.

9.4 Raw Genetic Data Access

The statistical data in Table 4.1 indicates that some of the compromised accounts were utilized in downloading raw files of genotype data by using data export feature in the platform. This fact is especially important as it proves that the attackers could receive extremely sensitive genetic data of users.

Disclosure of genetic data is one of the biggest privacy issues since any genetic data bears long lasting biological identifiers which cannot be altered or substituted once disclosed. Cybersecurity and privacy experts believe that the abuse of genetic data can lead to both long term and short term effects, including a threat of privacy loss and possible discrimination (Chow, 2025).

In the context of the investigation as a whole, this piece of evidence proves that the intrusion was more than simple profile data, it proves the intrusion of very sensitive biological data. This has a great impact on worsening the severity and legal consequences of the incident.

9.5 Overall Significance of Digital Evidence

All this digital evidence discovered during the investigation offers an in depth view of the way in which the 23andMe data breach took place and influenced millions of users around the world. The logs on the authentication prove the method of attack, the DNA Relatives data records prove the massive exposure of user data, and the artifacts of the dark web intelligence prove that user data has been distributed in the online environment.

Moreover, the case has emphasized the role of strong authentication controls, effective monitoring solutions and platform design security in working with highly sensitive personal and genetic information.

10.0 Expert Opinions

10.1 Attack Methods and Security Weaknesses

The 23andMe data breach of 2023 has been broadly described by analysts as a typical illustration of how credential stuffing assaults and underlying security faults may result in a huge loss of delicate computer-based resources. The root cause of the unauthorized access to 23andMe accounts was reported to be credential stuffing, a technique in which attackers use lists of previously leaked usernames and passwords to automate access (Holthouse, Owens & Bhunia, 2025). Technical analyses suggest that opponents used the duplication of credentials in other dissimilar services and used it to obtain unauthorized access without the need to break network defences or software vulnerabilities.

Security experts have pointed out that credential stuffing is not a new method but the achievement of this particular operation was reinforced by poor authentication measures. James McQuiggan, a security awareness advocate, noted that “multi-factor authentication should be the standard ... when accessing sensitive information like personally identifiable information,” highlighting that its absence critically increased the success rate of attackers (Jones, 2024). In fact, a report examining the breach revealed that although 23andMe was permitting optional MFA, it was not compulsory prior to the incident, and this created a security gap that attackers used (Black & Spratley, 2025).

Not only that, there are other expert interpretations indicating further flaws in authentication and monitoring controls. It was found that the password minimums at 23andMe were also very low as the company only required eight characters as passwords without any detect of known compromised passwords, and the company did not block or prevent repeat automated logins (Easy UK GDPR, 2025). Analysts also observed that there was no rate limiting on the number of attempts to log in, which is another important common defensive tactic that would lower the rate of credential stuffing success in large scale attacks (Parsons, n.d.).

According to the expert opinions above, the breach was not only a one-time hack but also a lapse in fundamental cybersecurity discipline and culture. The presence of these security vulnerabilities especially optional MFA, weak password policy and ineffective monitoring resulted in a conducive environment to allow credential stuffing to be successful and go undetected over months. Hence, these systemic weak spots should be heavily considered in terms of interpretation of the digital evidence as a factor contributing to the degree and time of the breach.

10.2 Regulatory Experts Interpretations

Regulatory bodies and legal analysts have expressed their strong opinions about the 23andMe breach, which revolves around the fact that the company did not comply with the established standard of data protection and cybersecurity. The Information Commissioner of the United Kingdom (ICO) found the genetic testing company had an inadequate level of security in place during the breach, specifically, not having mandated multi-factor authentication (MFA) and proper detection systems against automated credential stuffing attacks (ICO Report, 2025). The findings by the regulator are based on a comprehensive analysis of system controls and breach response data, which places these weaknesses not merely as technical failures, but as a violation of a reasonable organizational duty.

Besides, the timeliness of detection and disclosure of the breach by 23andMe was also criticized by regulators because they said that the company responded to the incident too slowly, and it was not consistent with cybersecurity and privacy-related law (ICO Report, 2025). This understanding is in line with the principles of the GDPR that mandate the immediate notification and reporting of breaches of personal data, especially when the personal data content is of a sensitive nature such as the one that is genetic in nature. According to regulatory experts, by pointing to the inefficiency of their monitoring and incident response infrastructure as the cause of the delay, the digital evidence such as the delayed logs, absence of real-time notifications, and unfinished audit trails, is indicative of systemic flaws but not technical glitches.

Furthermore, legal experts have also claimed that an organization cannot shift the blame onto the user by claiming that he or she did not maintain good password hygiene when it failed to

implement the essential protective measures. U.S. law criticism of the breach highlights that any company working with sensitive genetic and health information has an increased responsibility to put in place the right technical and organization controls, and the inability to do so may lead to regulatory fines and civil damages (Stempel, 2025).

10.3 Evidences Interpretations

Digital forensic experts have pointed out that the scope and method of the 23andMe breach could not be understood without first interpreting the system logs properly, access patterns, and authentication traces. The researchers of Enzoic found that through the examination of the logins, there were repeated automated attempts at the logins, which were validated as credential stuffing attacks where the IP addresses were geographically dispersed (Parsons, n.d.). These access patterns gave straightforward forensic hints of an unauthorized automated access as opposed to natural user access, enabling investigators to distinguish authentic user access best from malicious access attempts.

Cybersecurity analysts indicated as well the importance of missing or delayed notifications in the system monitoring logs. According to Holthouse, Owens, and Bhunia (2025), the lack of real-time notification of suspicious authentication attempts complicated the process of rebuilding the attack timeline, and the forensic professionals needed to use in-depth analysis of the post-incident logs to trace the actions of attackers. These interpretations explain why there are loopholes in detection systems, which may affect the perceived magnitude and length of a breach.

Some of the legal experts have also come up with their views on the consequences of digital evidence with regards to accountability in organizations. Jonathan Stempel (2025) pointed out that forensic evidence does not merely name the method of compromise, but also proves systemic vulnerabilities, including weak passwords policy and optional MFA which were a factor in the scale of the breach. This interpretation highlights that digital evidence has two purposes: to determine the activities of the attackers as well as to show the weaknesses in the security design of the organization.

Privacy and cybersecurity commentators also note that forensic analysis should take into consideration the sensitivity of the accessed information particularly in genetic databases. Evidence interpretation should take into consideration the irreversibility aspect of the information that has been exposed from the viewpoint of both the technical and ethical consequences of the breach (Chow, 2025). Altogether, the consensus of experts is that digital evidence does not only have a great role in re-creating events but also informing legal and regulatory determinations of liability and compliance.

11.0 Conclusions

The 2023 23andMe data breach represents a significant cybersecurity incident. It is due to the weaknesses in user authentication practices and the platform's interconnected DNA Relatives feature. Also, from the analysis of authentication and network logs, the potential victims might be about 6.9 million users, which is caused by the directly compromised 18,450 accounts. The investigation found that attackers used exploited login credentials to gain access to accounts, instead of internal system vulnerabilities. This demonstrates how risky it is to reuse the password and weak multi-factor authentication. The evidence, like WAF logs, server access records, and dark web intelligence artifacts, was handled properly by following the ISO 27037 and SWGDE standards to ensure court admissibility, integrity, and reliability.

In fact, the genetic information is highly valuable and has high research value because it is immutable and uniquely identifiable, and could be used for drug development and so on. This might be one of the reasons why attackers steal sensitive information, but this brings great impact to the user's privacy, especially those victims in this case. The exploitation of the DNA Relatives feature amplified the scope of the incident, which allows attackers to gain unauthorized access to users who had not directly been compromised. This incident also triggered regulatory scrutiny and legal proceedings under UK GDPR, PIPEDA, and Malaysian cyber laws.

Within the context of Malaysian cybercrime law, the incident aligns with multiple offences under the CCA 1997. For instance, unauthorized access to computer material (Section 3), unauthorized access with intent to commit further offences (Section 4), and abetment under Section 7. This case is a major offence in Malaysia, and it is because of the scale of affected data, the technical sophistication of the attack, and the sensitivity of genetic information.

Overall, the findings show that it is important to strengthen authentication systems, monitoring systems, and make sure to follow international and local data protection standards. This case is a warning to the policymakers and organizations in Malaysia to identify and mitigate potential risks associated with sensitive digital information and ensure compliance with cybercrime legislation.

12.0 Recommendations

1. Further digital evidence collection and verification
 - a. Check all authentication logs, WAF logs, and DNA Relatives access logs again, in case there is any gap or missing.
 - b. Repeat hashing using SHA-256 and chain of custody verification to make sure all evidence will be good enough for the checking in courts in Malaysia.
 - c. Cross-check with international regulatory reports to reinforce reliability
2. Engage expert witnesses for Malaysian court
 - a. Have forensic experts prepare court testimony explaining low-and-slow attacks and DNA Relatives exploitation.
 - b. Ensure experts align testimony with Section 45 (Evidence Act 1950) to interpret technical logs clearly for judges.
3. Map offenses to Malaysian Cybercrime Law
 - a. Mapping the attackers' actions to CCA 1997 Sections 3, 4, 5, and 7.
 - b. Provide supporting evidence to prove intent for further offenses, such as selling data on the dark web. So, the sufficiency can be fulfilled.
4. Strengthen evidence documentation
 - a. Maintain a detailed chain of custody, including all transfers to regulatory authorities and internal teams.
 - b. Create a legal brief summarizing key findings for court submission.
5. Additional investigations
 - a. Verify whether any accounts accessed could expose additional victims in Malaysia.
 - b. Investigate the possibility of secondary crimes, like identify theft that can strengthen charges.

13.0 References

1. United States Bankruptcy Court, Eastern District of Missouri. (27 June, 2025). *Order Approving Sale of Debtors' Assets in Bankruptcy Case (Case No. 25-40976-357)*. Retrieved from Alaska Department of Law: <https://law.alaska.gov/pdf/press/250630-Settlement.pdf>
2. United States District Court, Northern District of California. (12 September, 2024). *Class action settlement agreement and release in In Re: 23andMe, Inc. customer data security breach litigation, MDL No. 24-md-03098-EMC*. Retrieved from ClassAction.org: <https://www.classaction.org/media/23andme-data-breach-settlement-agreement.pdf>
3. Information Commissioner's Office. (2025). *Penalty Notice: 23andMe, Inc. (Reference: COM0918731)*. Retrieved from <https://ico.org.uk/media2/kclbljpo/23andme-penalty-notice.pdf>
4. Office of the Privacy Commissioner of Canada. (17 June, 2025). *PIPEDA Findings #2025-001: Joint investigation into 23andMe, Inc. regarding a credential stuffing cyberattack*. Retrieved from <https://www.priv.gc.ca/en/opc-actions-and-decisions/investigations/investigations-into-businesses/2025/pipeda-2025-001>
5. Office of the Privacy Commissioner of Canada. (17 June, 2025). *Background: Timeline of 23andMe investigation and subsequent enforcement*. Retrieved from https://www.priv.gc.ca/en/opc-news/news-and-announcements/2025/bg_23andme_250617/#chrono
6. 23andMe. (n.d.). *DNA Genetic Testing & Analysis - 23andMe*. 23andme.com. <https://www.23andme.com/>
7. 23andMe. (2023, October 7). *Addressing Data Security Concerns*. 23andMe Blog. <https://blog.23andme.com/articles/addressing-data-security-concerns>
8. Black, R., & Spratley, D. (2025, June 24). *Compliance recommendations from Privacy Commissioners' report on 23andMe data breach | DLA Piper*. DLA Piper. <https://www.dlapiper.com/en-hk/insights/publications/2025/06/compliance-recommendations-from-privacy-commissioners-report-on-23andme-data-breach>
9. Chow, A. R. (2025, March 26). *Why 23andMe's Genetic Data Could Be a "Gold Mine" for AI Companies*. TIME; Time. <https://time.com/7271463/23andme-data-ai-bankruptcy/>

10. Easy UK GDPR. (2025, June 30). *Lessons from the 23andMe Data Breach: A UK GDPR Guide for Small Businesses*. Easyukgdpr.co.uk.
<https://easyukgdpr.co.uk/2025/06/30/lessons-from-the-23andme-data-breach-a-uk-gdpr-guide-for-small-businesses/>
11. Holthouse, R., Owens, S., & Bhunia, S. (2025). The 23andMe Data Breach: Analyzing Credential Stuffing Attacks, Security Vulnerabilities, and Mitigation Strategies. *ArXiv (Cornell University)*. <https://doi.org/10.48550/arxiv.2502.04303>
12. Jones, C. (2024, January 4). *Infosec experts divided over 23andMe's "victim-blaming" stance on data breach*. Theregister.com; The Register.
https://www.theregister.com/2024/01/04/23andme_victim_blaming_breach
13. Parsons, J. (n.d.). *Lessons from the 23andMe Breach and NIST SP 800-63B*. Enzoic.
<https://www.enzoic.com/blog/23andme-breach/>
14. Stempel, J. (2025, September 6). 23andMe seeks approval of larger, \$50 million data breach settlement. *Reuters*. <https://www.reuters.com/legal/government/23andme-seeks-approval-larger-50-million-data-breach-settlement-2025-09-05/>
15. BluOcean Cyber. (n.d.). *From Data Breach to Bankruptcy: The Downfall of 23andMe and Key Lessons for Businesses*. Retrieved from BluOcean Cyber:
<https://bluoceancyber.com/downfall-of-23andme/>
16. Sekurno. (7 April, 2025). *The 23andMe Breach: Anatomy, Impact, and Lessons for Genomic Security (Deep Dive)*. Retrieved from Sekurno:
<https://www.sekurno.com/post/the-23andme-breach-anatomy-impact-and-lessons-for-genomic-security-deep-dive>
17. Splunk. (n.d.). *Splunk Enterprise Security*. Retrieved from Splunk:
https://www.splunk.com/en_us/products/enterprise-security.html
18. Wireshark. (n.d.). *Chapter 1. Introduction*. Retrieved from Wireshark:
https://www.wireshark.org/docs/wsug_html_chunked/ChapterIntroduction.html
19. BINUS UNIVERSITY. (20 September, 2023). *FTK IMAGER IN DIGITAL FORENSIC*. Retrieved from BINUS UNIVERSITY School of Information Systems:
<https://sis.binus.ac.id/2023/09/20/ftk-imager-in-digital-forensic/>